INKLOOM AI · BRAND GOVERNANCE CHALLENGE · ROUND 3: THE FINISH

Canonry

Brand governance before publication: every issue explained, cited and fixable, a person decides, and the approval is sealed so anyone can verify it later.

Live product: https://canonry-sigma.vercel.app (pick a role, *Continue as guest*; tick *Show me around* for a guided first visit)
Source code: https://github.com/Dhruv-Puri/Canonry (public, branch `main`; README → Quick start runs it in about 5 minutes)
Engine health: https://canonry-engine.onrender.com/health (free tier: the first visit after idle can take ~50 s)

Team vaidvansh6 · Vansh Vaid (team leader) · Dhruv Puri Round 3 submission · 3 November 2026

3 / 3
promised improvements delivered and live: documents & images, publishing gate, India pack

32
automated test suites + an evaluation gate, run in CI on every push

185 / 185
browser checks: every role, hostile input, double clicks, two tabs, phone layouts

43 / 45
real ASCI-upheld misleading ad lines caught by the India pack; 0 false alarms on 10 controls

DEMO ACCOUNTS ARE SHARED ON PURPOSE

The live link runs in **demo mode** so judges can try all four roles without signing up: every visitor shares one sample brand (Quillmark, fictional) and can switch role from the top bar. A real deployment runs in **production mode**: one-use invitations, each person's own password, the role fixed by the invitation, agency partners isolated to their own work, and no self-approval. Both modes are in the code and covered by tests (`test_identity` , `test_access`).

In this report

1 Problem and users
2 Solution and workflow
3 Completed features
4 The three improvements, delivered
5 Technology and architecture
6 Testing and reliability
7 Privacy, security, accessibility, responsible design
8 Changes from the plan
9 Impact
10 Known limitations
11 Roadmap
12 Team, contributions and disclosures

1 Problem and users

Marketing content is written by many hands (in-house writers, agencies, and now AI tools) and published across many channels. Brand guidelines live in PDFs nobody re-reads; approved facts (prices, customer counts, certifications) change and expire; and in India, the CCPA's 2022 guidelines and the ASCI Code make a misleading claim a legal risk, not just an embarrassment. Review today is a person reading every line against memory. It is slow, inconsistent, and leaves no proof of what was approved.

What a good answer must do (from the brief and our Round 1 research): catch off-brand wording, wrong or outdated facts and risky claims *before* publication; explain each issue so a writer can fix it; keep a person in charge of the decision; and work for the files and systems teams actually use.

User	Needs	What Canonry gives them
Creator (in-house writer)	Know what is wrong and how to fix it, quickly; know what the reviewer decided	Cited findings with one-click fixes; **My work** with each verdict and the reviewer's words; edit and resend
Reviewer / brand owner	Review only what matters; decide with evidence; leave a record	A risk-routed queue; approve, send back or override with a reason; a signed Proof of Compliance
Agency partner	Submit work for a client brand without seeing other work or confidential facts	An isolated view of their own submissions; confidential facts redacted
Brand admin	Keep rules and facts current; see where guidelines fail; connect publishing systems	A versioned knowledge base with change impact; Insights; API keys, signed webhooks and compliance packs
Anyone outside (a partner, a regulator, a customer)	Check that what was published is what was approved	A public verify page: paste the text or upload the file, no account

2 Solution and workflow

Canonry is a pre-publication review workspace. Its principle, kept from the Round 1 plan, is **rules before AI**: deterministic checks are free, fast and certain; an AI model handles only what patterns cannot (implied claims, tone, what a picture shows), and the product still works with no AI key at all. Every finding must cite a real rule, fact or legal clause (*no citation, no finding*), carries a confidence tier (*Must fix*, *Should fix*, *Worth a look*), and the AI never decides.

1 · Write paste text, or upload PDF, Word, PNG, JPEG; or send through the API › **2 · Understand** what the content is: format, kind, purpose, audience, claims; which checks apply › **3 · Check** terms, facts, claims, tone, confidential leaks, images, India pack › **4 · Fix** accept, edit or dispute each finding; every change is re-checked › **5 · Review** approve, send back with a reason, or override a finding › **6 · Sign** Ed25519 Proof of Compliance, stamped into the file › **7 · Verify** anyone checks the published text or file; webhooks release it to the CMS

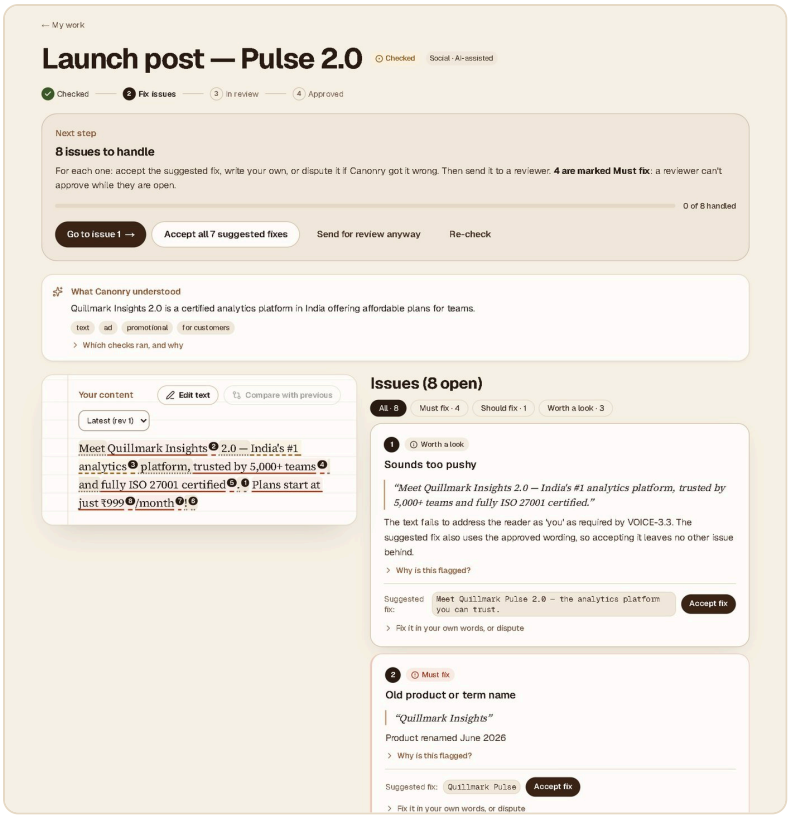


Figure 1. The sample launch post on the live site, checked with real AI: what Canonry understood, the next step, and each finding quoting the words, explaining the problem, citing the rule or fact (the approved count 2,300+, the renamed product, the expired ISO certificate, the superseded price) and offering a fix that is itself re-checked.

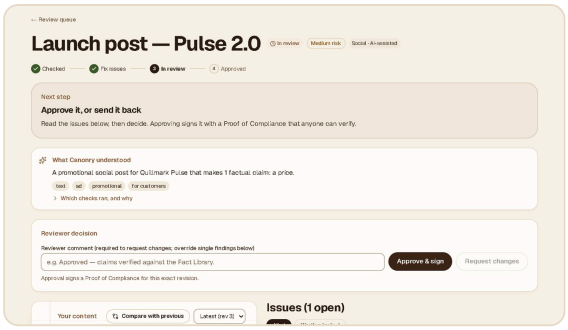


Figure 2. The reviewer approves and signs, sends back with a comment, or overrides one finding with a reason.

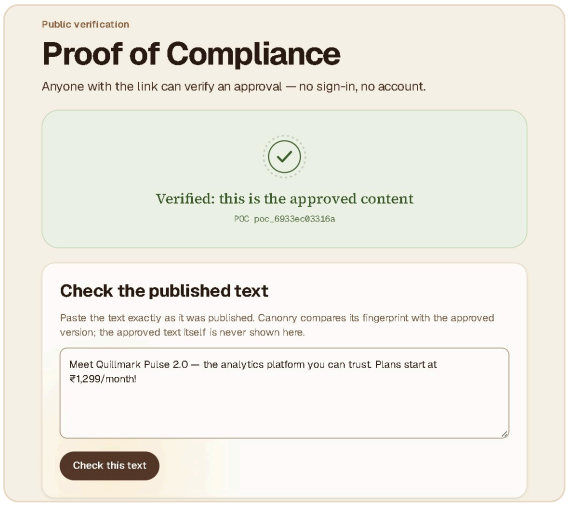


Figure 3. Public verify page, signed out: the published text matches the approved fingerprint; one changed character shows *Modified*.

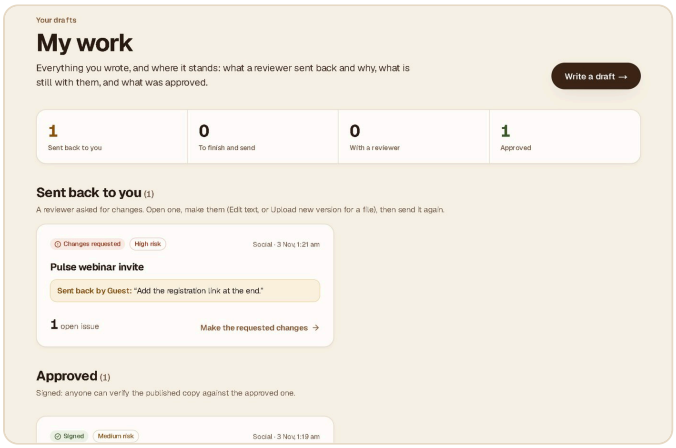


Figure 4. My work (new in Round 3): each writer's drafts grouped by where they stand, with the reviewer's verdict and words on the card.

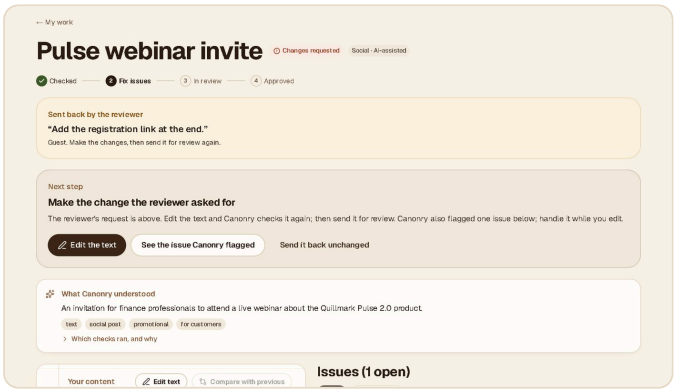


Figure 5. A sent-back draft leads with the reviewer's request; *Edit the text* makes a new, checked revision for the reviewer.

3 Completed features

Checking

- **Understand first:** each check starts by reading what the content is and runs only the checks that fit (no "add a call to action" on an internal note); denied, attributed and quoted claims are read in context.
- **Rule checks:** approved and retired terms (whole phrases), readability, tone, calls to action, confidential-fact leaks.
- **Claims against an approved fact library:** numbers matched by value ("2,300+" never matches "3,200+"); expired and superseded facts caught; Verified Claim Memory reuses a verdict only for identical claims and knowledge version.
- **AI-assisted** implied claims and tone on free models, with honest degradation: rule findings always arrive, and the page says why AI was skipped.
- **One card per issue** (duplicates from different checks merge); a suggested fix is never shown if it would bring back another issue; every rule an explanation names is cited.
- **Files and images** (Improvement 1) and the **India pack** (Improvement 3), section 4.

Deciding

- Accept, edit or dispute each finding; "Accept all suggested fixes"; word-level comparison of revisions.
- Risk router (low, medium, high, exempt); approve, request changes, or override a finding with a reason.
- **My work** for writers with each verdict; **Edit the text** of a draft that is with them.
- Approved content is locked; everything is recorded in the history.

Proof

- **Proof of Compliance:** SHA-256 of the approved content, approver, knowledge and pack versions, time; signed with Ed25519 and hash-chained.
- The approved PDF, Word, PNG or JPEG carries its signed proof in its own metadata.
- Public verify page for pasted text or an uploaded file; a changed file, or a real seal copied onto other bytes, does not verify.

Knowledge and insight

- Versioned rules, facts and terms with history; rule linting (vague, contradictory, duplicate); change-impact preview shows which approved content a rule edit would newly break; fact-expiry alerts.
- **Insights:** what gets caught most, disputes and overrides, rules that need clearer wording, and **claims with no fact behind them**, which a reviewer can add as an approved fact in one step (the knowledge base grows from use).

Platform

- Four roles; agency isolation; confidential redaction; demo and production modes; invitations and passwords.
- REST API, signed webhooks and a demo publisher (Improvement 2).
- Daily AI allowance per person (5) and workspace (50), so one visitor cannot drain the free keys.
- First-visit walkthrough and a role tour; phone layouts for every screen.

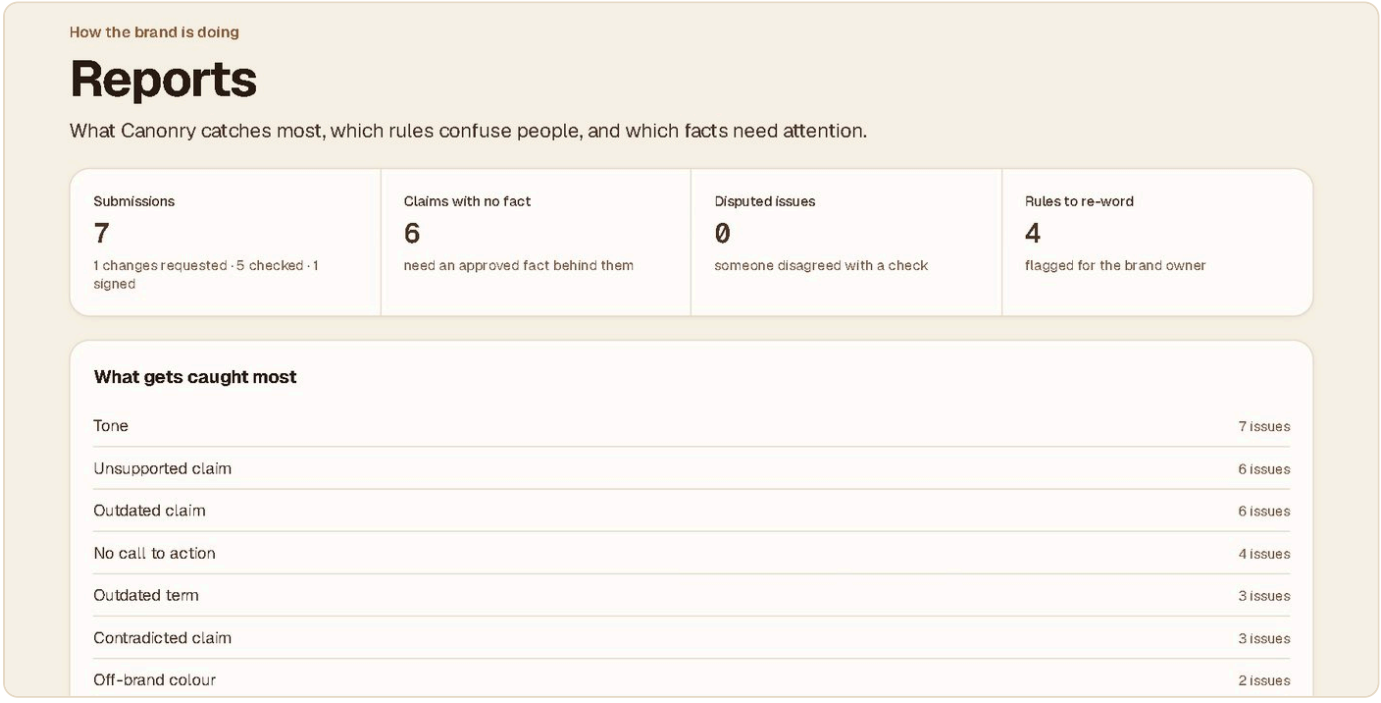


Figure 6. Insights for the brand owner: what gets caught most, claims with no approved fact behind them (each can become a fact), and rules that need clearer wording.

4 The three improvements, delivered

These are the three improvements promised in the Round 2 submission. All three are on the live site, each with automated suites and a live check.

Improvement 1 · Documents and images delivered

Promised	Delivered
DOCX and PDF upload; findings point to page and line	PDF findings show **page and line**, Word findings **section and paragraph**; every text check runs on the file's text. **Word fixes are made inside the .docx**, keeping its formatting; PDFs and images are fixed in their source and uploaded as a **new version** of the same submission.
Logo, brand colour, contrast (WCAG) and alt-text checks	Words in images read with Tesseract and checked like copy; **contrast per line** against WCAG AA, boxed on the preview; the brand logo found at any size (OpenCV ORB + homography) and checked for a retired version, stretching, tilting, recolouring, busy background, clear space and size; palette by ΔE 2000; alt-text quality.
Proof stamped into the approved file	PDF, Word, PNG and JPEG carry their signed proof in metadata; the verify page checks an uploaded file.
Added	**Image understanding**: with Gemini, one call per image says what Canonry sees (brands, a competitor's logo, retired names, claims drawn into the picture, whether it fits its caption) and suggests alt text; its findings are never above *Should fix*.

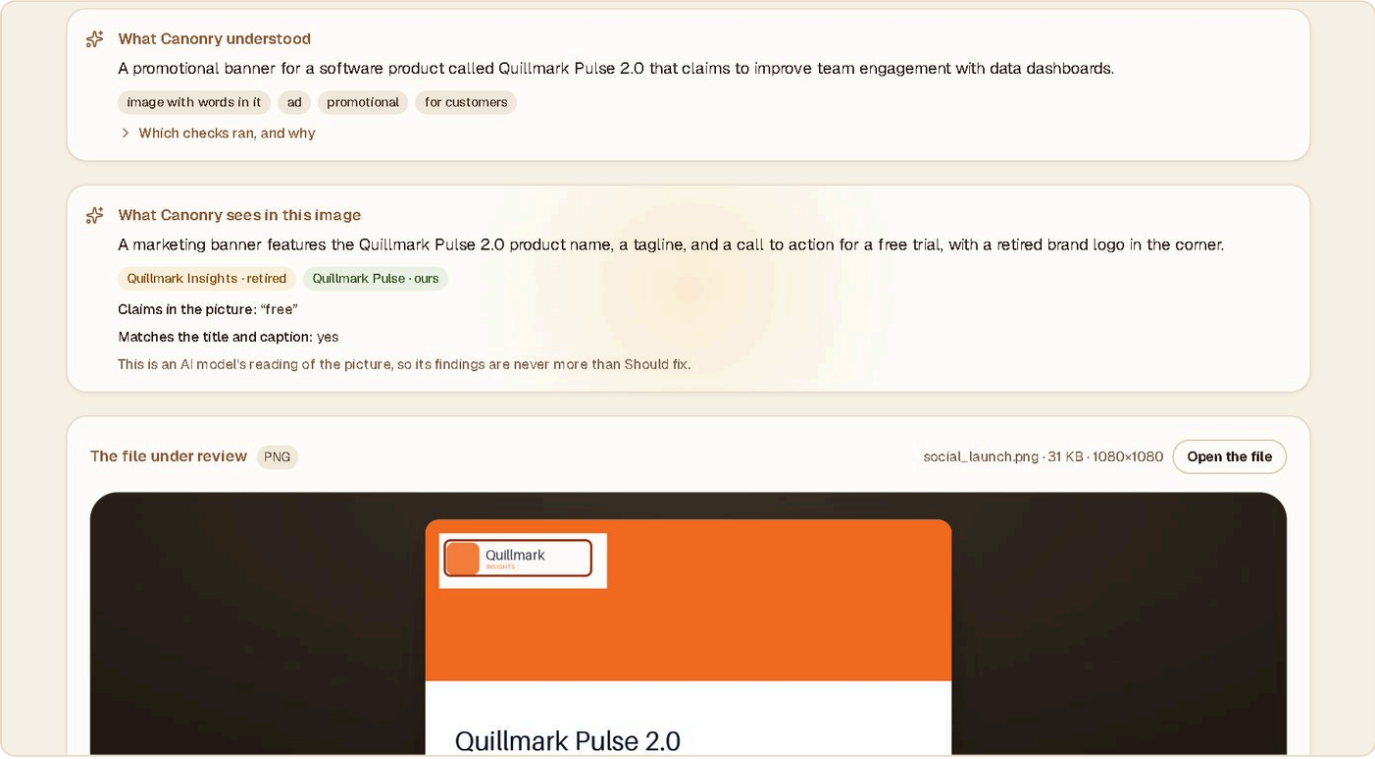


Figure 7. A social banner checked on the live site: what the vision model sees (a retired logo, the claim "free"), the findings boxed on the picture, and the retired logo flagged as *Must fix*.

Evidence: suites `test_documents`, `test_image_text` (real Tesseract), `test_logos`, `test_docx_fix`, `test_vision`, `test_large_images`; live: a 4000×3000 photo checked within the free server's 512 MB, and real Gemini image understanding.

Improvement 2 · Publishing gate: REST API + signed webhooks delivered

Promised	Delivered
Versioned API with per-workspace keys	`/api/v1` checks, uploads, submissions, proofs, assets, packs; keys shown once, stored as SHA-256, scoped (check, read, admin), revocable; **idempotent** requests (a retry never makes a second submission); plain error codes; size limits.

Webhooks on *checked*, *approved*, *signed*	Written to an outbox with the event; **HMAC-SHA256 signed** with a timestamp; retried on a schedule (30 s to 6 h, 8 attempts); rotate, disable, delivery log; HTTPS only, and private, loopback and cloud-metadata addresses refused before every attempt.
A CMS that holds a post until approval	The **demo publisher** (`/engine/cms` on the live site) sends a post to Canonry and publishes it only when a valid *signed* webhook arrives *and* the approved text's hash matches; *approved* alone is not enough.

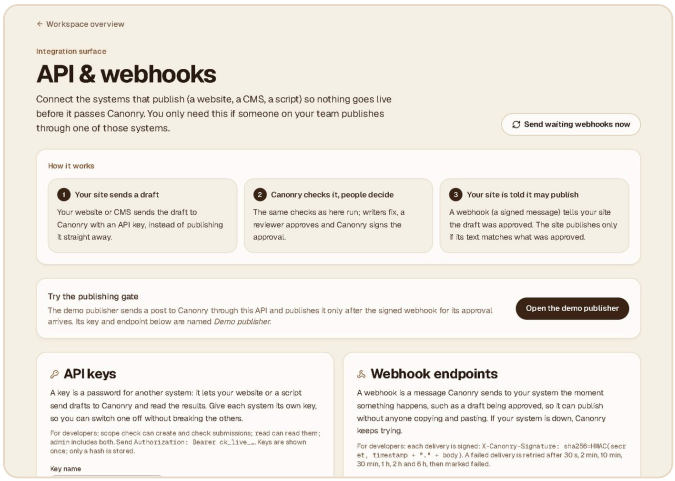


Figure 8. Brand admin → API & webhooks: how the gate works in three steps, keys, endpoints and every delivery.

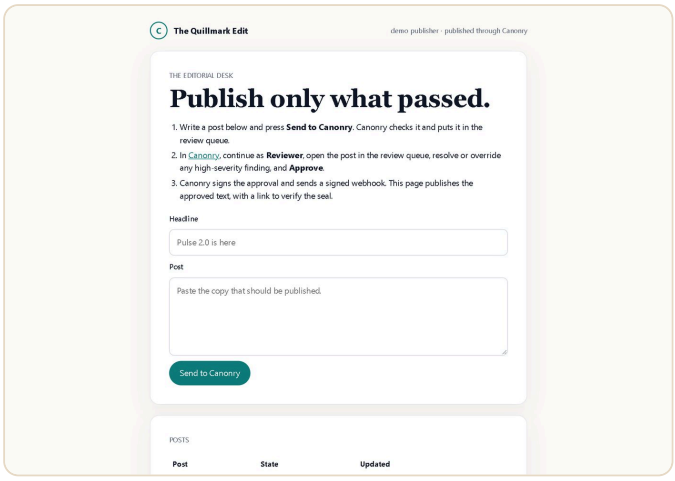


Figure 9. The demo publisher: "Publish only what passed." A post waits until Canonry's signed approval arrives.

Evidence: `test_api` (keys, scopes, idempotency races, address checks, HMAC, retries), `test_publisher` (real HTTP webhooks on a real server), `test_api_gate`. Not built: the stretch Google Docs add-on.

Improvement 3 · India advertising compliance pack, with retrieval `delivered`

Promised	Delivered
Rules from the CCPA Guidelines (2022) and the ASCI Code	13 clauses as data (`india_advertising_pack.json`): bait offers, "free" claims, disclaimers, substantiation, "up to" claims, endorsements, comparisons, children and more. A new market is a new file.
Retrieval of the relevant clause; exact citation	Each sentence retrieves its nearest clauses with embeddings (stored in SQLite on the demo); only retrieved clauses can produce a finding, which cites source, section, clause text and a link. Numbers are never interpreted by a model. The seal records the pack version.
"Definite" findings at ≥ 95% precision	On 32 labelled sentences: **100% precision and recall**, no false alarm at any tier; 14 lines of ordinary copy stay silent.
Added: tested on real decisions	**45 ad lines that ASCI upheld complaints against**, quoted from published reports: the pack first caught 2 of 45; after new leadership, guarantee, cure and offer patterns it catches **43 of 45**, with no warning on 10 compliant lines using the same words. The patterns were written after reading the cases, so this is not a blind score (section 10).

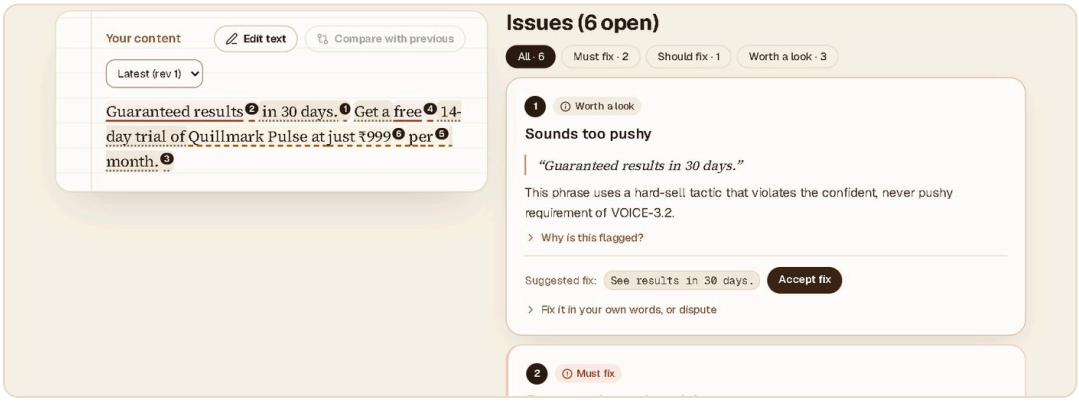
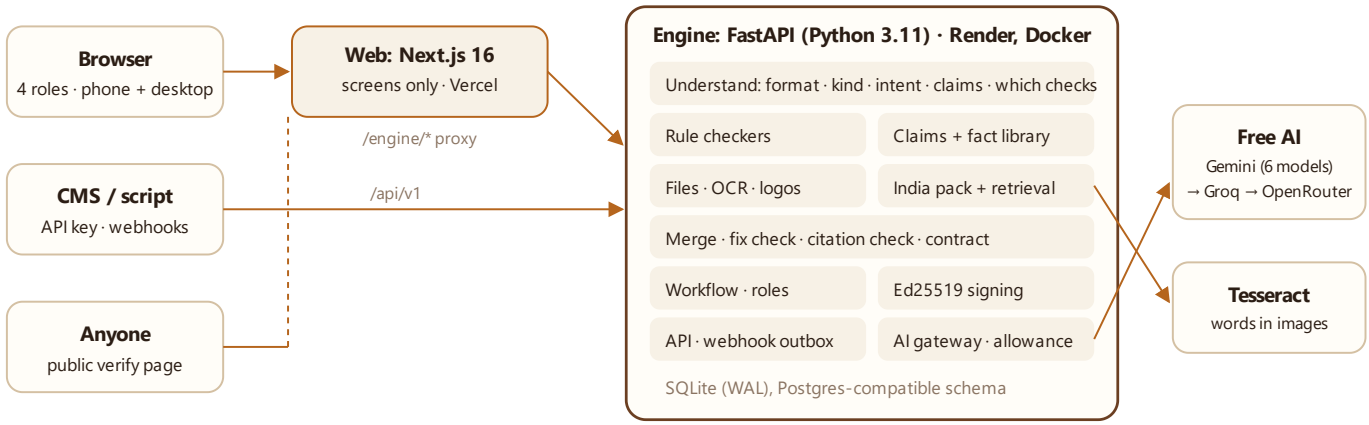


Figure 10. "Guaranteed results in 30 days": *Must fix*, citing CCPA Guidelines 2022 Section 12(a), duty to substantiate claims, with how to fix it.

5 Technology and architecture



Main technical decisions

- **One engine holds every rule**; the web app only renders and reaches it through a same-origin proxy, so cookies stay first-party and there is no CORS.
- **Understand first, rules decide:** the content profile is deterministic, so a re-check and the evaluation gate always give the same answer; the AI may refine the summary but never which checks run.
- **Exact matching for facts**, embeddings only to retrieve legal clauses: a number is never a "similar" number.
- **Free models only**, at most 3 answered calls per 1,000 words; confidential facts are never sent.
- **Built for free-tier AI:** a busy model is cooled down and the next tried; a call still running after 4 s gets a second model asked, and the first answer wins; calls stop at 15 s and a stall is never retried (measured live: the same check took 3 s or 28 s before, 3–5 s after).
- **Memory-safe images** on a 512 MB server: logo search on a ≤2000 px working copy, text prepared in strips, one image job at a time (a 4096 px upload needed ~380 MB; now ~160 MB).
- **SQLite now**, Postgres-compatible schema; Postgres + pgvector written but not deployed (section 8).

What we used

Layer	Choice
Web	Next.js 16, React 19, Tailwind CSS 4, Radix UI, lucide-react
Engine	FastAPI, uvicorn, pydantic, httpx, PyNaCl (Ed25519)
Files	pypdf, lxml (Word), Pillow, NumPy, OpenCV (headless), Tesseract OCR
Data	SQLite (WAL); psycopg + pgvector path in code
AI (runtime)	Gemini free tier (`gemini-3.1-flash-lite` and 5 fallbacks), Groq `llama-3.1-8b-instant`; OpenRouter and local Ollama supported
Protocols	REST, HMAC-signed webhooks, MCP (Canon Connector, local)
Hosting	Vercel (web), Render (engine, Docker), GitHub Actions (CI); all free tiers
Data set	Fictional Quillmark brand book: 43 rules, 41 facts, 10 terms; India pack 13 clauses; 45 real ASCI cases + 10 controls

6 Testing and reliability

AUTOMATED

32 suites + evaluation gate, each on a fresh database, run in CI on every push with a web type-check, a production build, `pip-audit` and `npm audit`. They never call a real AI provider: malformed answers, stalls and timeouts are tested with fake providers.

BROWSER

185 / 185 checks driving Microsoft Edge: every role's journey, hostile input (blank, 120,000 characters, emoji, Hindi, RTL, HTML; wrong, renamed, cut-off and empty files), double clicks, refresh and back, two tabs, an expired session, unknown ids, and every screen at 1280 and 390 px.

LIVE SITE

The first-visit walkthrough, clicking exactly what the guide points at: **27 / 27**. The writer's loop (sent back → edit → send again → approved): **16 / 16**. Both on the live site with real AI and OCR, desktop and phone.

Measured quality

What	Result	How
Claim checking (Round 1 improvement)	recall 100%, precision 100% (targets 85% / 80%)	frozen evaluation split; gate fails CI on any regression
Citations	0 findings shown with a missing or inactive citation	citation check on every finding; contract `finding@1`
India pack, labelled set	100% precision and recall; 0 false alarms at any tier	32 sentences (20 violations, 12 near-misses) + 14 ordinary lines
India pack, real ASCI decisions	43 of 45 caught; 0 warnings on 10 controls	published upheld complaints; gate requires ≥ 90%
Speed	a 50,000-character draft checked in about a second; a check with AI usually 3–5 s live	`test_long_draft`; live timings, 3 Nov

Bugs found by testing and fixed (selection; each held by a test that failed first)

Bug	Effect	Fix
Free AI model answered in an unexpected JSON shape	"Internal Server Error" on submit, seen live	answers validated; any surprise keeps the rule findings (`test_ai_shapes`)
One slow AI call held the database lock	every other visitor locked out while it waited	no lock held during AI calls (`test_slow_ai_lock`)
A real seal copied onto another file	the forged file showed "verified"	only the approved file or its stamped copy verifies
Double click on Approve; two tabs on one draft	two seals; an old tab could undo newer fixes	one approval = one seal; a stale tab is told and reloads (`test_reliability`)
Retries with one Idempotency-Key	two submissions and a 500	a retry in flight answers 409, never a duplicate (`test_api`)
"feel free", "partner", "better than ever"	legal warnings, two approval-blocking	pack patterns tightened; false alarms gated at every tier
"Rs. 999", "No. 1" split sentences	the India pack missed real ASCI cases	sentence splitter fixed for every checker
A 4096 px image upload	~380 MB on a 512 MB server: a crash wipes the demo	working copies and one image job at a time (`test_large_images`)
"5 minutes", "Pulse 2.5", "₹1,599"	flagged as the banned term "5,000+"; "#10" as "#1"	whole-phrase matching (`test_term_matching`)
A stalled free AI model	the same check took 3 s or 28 s; one took 58 s	second model after 4 s; 15 s cap; no retry on a stall (`test_gateway`)
Sent-back draft with an AI finding	"1 issue to handle" hid the reviewer's request	the request always leads (found by the live run)

Full lists: `docs/progress.md`; every decision with its reason: `docs/decision-log.md` (D1–D80).

7 Privacy, security, accessibility and responsible design

Privacy

- Only the content being checked and the **publishable** facts it needs go to an AI provider, never the whole knowledge base and never a confidential fact (tested on every outgoing request).
- With no AI key, nothing leaves the server; rule checks still run.
- The vision call sends the image (at most 1024 px), its title and alt text, and the brand's own names; it is asked never to identify people.
- Confidential facts are redacted for writers and agency partners; agencies see only their own work.
- No analytics or tracking scripts. Demo data is fictional; the demo warns visitors not to enter real brand material.

Security

- Sessions in httpOnly, SameSite cookies; cross-origin requests refused; passwords hashed with PBKDF2-SHA256 (310,000 rounds); one-use, expiring invitations; no self-approval in production.
- API keys stored as SHA-256 and shown once; scopes; revocation takes effect at once.
- Webhooks signed with HMAC-SHA256 and a timestamp; webhook hosts must be public HTTPS, re-checked before every attempt; redirects not followed.
- Uploads checked by content, not name; Word zip bombs, damaged parts and hostile embedded seals refused; size limits.
- Approvals signed with Ed25519, hash-chained; a seal cannot be moved to other content.
- CI runs `pip-audit` and `npm audit`.

Accessibility

- **In the content:** text contrast in images measured per line against WCAG AA; alt text checked (missing, "image of…", file names, length) with a suggested replacement.
- **In the app:** labelled form fields and ARIA roles, visible keyboard focus, reduced motion respected, readable on a 390 px phone; the browser run fails on unlabelled inputs, images without alt text and sideways scrolling on every screen.
- Plain-language findings and errors: what is wrong, why, and what to do next.
- Not yet done: an automated axe-core audit and a screen-reader pass (roadmap).

Responsible design

- **People decide.** The AI suggests; only a person approves, and high-severity findings block approval until fixed or overridden with a written reason.
- **No citation, no finding.** A finding whose rule, fact or clause does not exist is discarded.
- **Honest confidence.** AI and image-understanding findings are never above *Should fix*; the India pack is labelled "not legal advice".
- **Honest degradation.** When AI is skipped, the page says why and when it resets; nothing is silently left out.
- **Disputes are data:** a disputed or overridden finding feeds Insights, so the rules get clearer instead of people learning to ignore warnings.
- **Free for small teams:** works on free AI tiers or none, with a daily allowance so one user cannot exhaust a shared key.

8 Changes from the plan

Planned	Status	What changed, and why
Three Round 3 improvements	Delivered	All three, live and tested (section 4); image understanding and the real-ASCI test were added.
India pack retrieval on managed Postgres + pgvector	Written, not deployed	A free managed database is a second service that can sleep or fill up during judging, and every check would depend on it; the demo keeps the same vectors in SQLite. The code path exists (`CANONRY_DATABASE_URL`).
Google Docs add-on (stretch)	Not built	The API it would use is built; the add-on is on the roadmap.
Five-person usability study (SUS)	Not run	The kit is ready (`docs/usability-test-kit.md`); an internal heuristic review of every screen was done instead and is not a substitute.
Larger, independently labelled evaluation set	Not done	The India pack was instead tested on real ASCI decisions; the claim set is still 20 team-labelled samples.

Not planned	Added	Understand-first checks; one card per issue; image understanding; a knowledge base that grows from Insights; My work and text editing for writers; memory limits for large images; fixes for slow free AI models.
Not planned	Left out	Audio and video (a header-checking module exists, not wired in); payouts, budgets and multi-brand management, which are outside the brief.

Round 1 → Round 2 changes are in the Round 2 PDF and `docs/plan-vs-build.md`, which now also has this Round 3 table.

9 Impact

What Canonry changes, stated only as far as we have measured it:

- **Wrong facts stop before publication.** On the sample launch post, seven issues (a renamed product, an unsupported "#1", a customer count that contradicts the approved figure, an expired certification, a superseded price) are caught, cited and fixed in a few clicks; every number in the approved version traces to an approved fact.
- **Legal risk becomes visible to writers.** 43 of 45 ad lines that ASCI upheld complaints against are flagged with the clause that applies, before a regulator or competitor sees them.
- **Review is provable.** Every approval is a signed record anyone can check, and the publishing gate means unapproved content cannot reach the CMS.
- **Guidelines improve.** Disputes, overrides and unbacked claims show where the rules are unclear or the fact library is missing something.

Not yet measured: time saved per review and user satisfaction. Both need the usability study and a pilot with a real team (roadmap).

10 Known limitations

Limitation	Detail
Free hosting	The engine sleeps when idle: the first visit can take ~50 s. Demo data resets when the free server restarts, and the signing key is regenerated, so seals made before a restart verify as *unknown*.
Shared demo	Guests share one sample workspace and can switch to Reviewer and approve their own draft (labelled *self-approved*); production mode prevents both.
Free AI models	Usually 3–5 s; up to ~20 s when the free models are at their per-minute limit; the AI part is skipped (with the reason shown) when every free provider is busy or the daily allowance is used. AI findings are judgement calls and can be wrong.
India pack	Rule patterns, not legal advice; 43/45 is not a blind score; it still misses a No. 1 claim backed by an out-of-date survey and one product-name claim ("1 Shot Dandruff Killer").
Files	PDF, Word, PNG and JPEG up to 4 MB through the web app (10 MB through the API); scanned PDFs without text are refused; PDFs and images are fixed in their source; English only; logo checks only know the logos in the brand kit.
Not in this round	Audio and video; email or Slack notifications; region routing and SLA reminders; the MCP connector runs locally only.
Evidence still to collect	No usability study yet; the claim evaluation set is small (20 samples) and team-labelled; CI tests the AI path with fake providers only.

11 Roadmap

#	Next	Why	First step
1	**User testing**	No real users have used Canonry yet	Run the prepared 5-person SUS study on the live link; fix the top three issues

2	**Managed Postgres + pgvector live**	Data, seals and clause retrieval should survive restarts	Point the engine at a free Neon or Supabase database; run the suites against it in CI
3	**Persistent signing keys**	Seals should verify forever	A stored key (paid disk or a key-management service) with key rotation
4	**Blind-tested India pack**	43/45 was scored after reading the cases	A fresh set from newer ASCI reports, labelled outside the team, scored before any change
5	**Larger evaluation set**	20 team-labelled samples is small	200 samples labelled outside the team; keep the 85% / 80% targets
6	**Where people write**	Checks should happen while writing	Google Docs add-on and the MCP connector, on the existing public API
7	**Accessibility audit**	The app's own accessibility is checked by our browser run only	axe-core in CI and a screen-reader pass
8	**Audio, video, more markets**	Ads are often video; brands publish in many markets	Wire `engine/media.py` with transcripts into the claim checks; more market packs as data

12 Team, contributions and disclosures

Member	Contribution
Vansh Vaid team leader · product, web, workflow, reliability, documentation	Round 1 plan; product direction across rounds; web screens and the review workflow; Round 2 hardening, versioned knowledge base and identity. Round 3: Word, OCR and logo checks on the shared file pipeline; image understanding; understand-first checks; the India pack's test on 45 real ASCI cases; the knowledge base that grows from Insights; memory limits for large images; **My work** and text editing; the banned-term fix; the fixes for slow free AI models; the browser test scripts; deployments; the documentation and this report.
Dhruv Puri analysis engine, retrieval, AI gateway, evaluation	Initial engine and project setup; Gemini model fallbacks, the AI time limit, and the admin, agency and review pages. Round 3: the base for all three improvements in one commit (`6bf69fc`): document and image upload, file stamping, the REST API and webhooks, the demo publisher, the India compliance pack with clause retrieval and embeddings, and the admin API page; the role-specific tour and document viewer; the audio/video module and the API-gate test.

AI assistance, disclosed (`docs/disclosure-log.md`): Anthropic Claude (Claude Code) drafted code, tests, documentation and this report under the team's direction; the GitHub Copilot coding agent made two commits (approval signing in one transaction, SQLite lock escalation) merged after review; Google Gemini drafted a UX brief that the team filtered. Every change was reviewed, tested and merged through pull requests. Libraries, services and data sources are listed in sections 5 and the disclosure log. All product code was written during the official build windows; the Quillmark brand is fictional.

> **WHERE TO LOOK**
>
> **README** (start here: what to try, quick start, tests, limitations) · **docs/round3-submission.md** (form answers) · **docs/decision-log.md** (80 dated decisions) · **docs/progress.md** (bugs found and fixed) · **docs/plan-vs-build.md** (changes from the plan) · **docs/architecture.md** · **docs/disclosure-log.md** · Round 2 PDF with the Round 1 plan (`docs/`).